Product quality report · vertical-slice · build e6c512ea-1f27-4b92-a0e3-cea54f37a145

Pong data maturity scan versie 2

Assessed against the **MVP for a limited pilot** quality bar · generated 2026-10-13T18:09:17.178112206Z

Verdict

× Not ready

Does not meet the requested quality bar yet.

- A verified security blocker forces Not ready under this quality bar.
- Completeness 60% is below the required 70%.
- 4 verified blocker(s); at most 0 allowed.
- Dimension security scores 3; at least 4 required.
- Completeness 60% is below the required 85%.
- 15 verified major finding(s); at most 6 allowed.
- Dimension architecture scores 5; at least 6 required.
- Dimension uiUx scores 5; at least 6 required.
- Dimension security scores 3; at least 6 required.
- Dimension scalability scores 5; at least 6 required.
- Dimension dataIntegration scores 5; at least 6 required.
- Dimension operations scores 4; at least 6 required.

Fix first

1. × Security · blocker Authentication is opt-in through a JAX-RS name binding
2. × Security · blocker Admin endpoints authenticate users but do not authorize a privileged role
3. × Security · blocker Production configuration has usable default credentials and signing secret

Requested requirements delivered

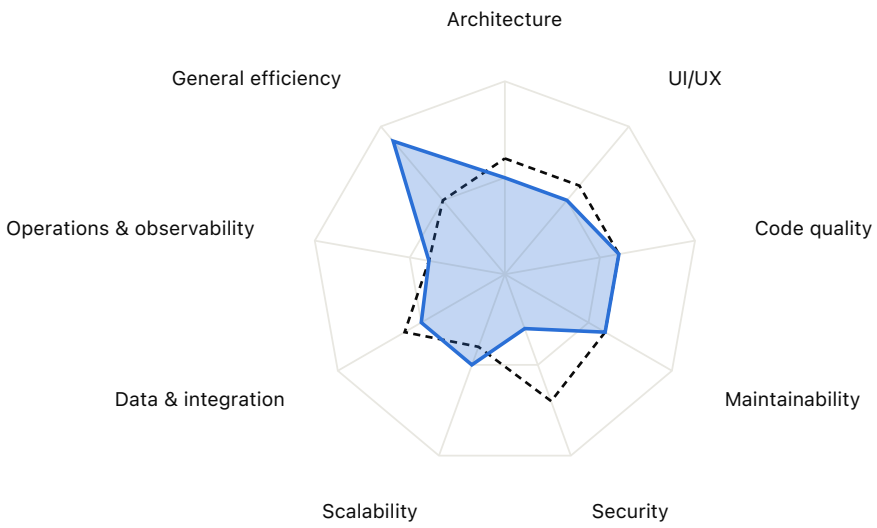
60%

✓ 63 met ◐ 62 partial × 31 unmet

156 requirements · met counts fully, partial counts half · 4 verified blocker(s) · 15 major · weighted overall 5/10

Scorecard

Each score is 0–10 against the quality bar. The filled shape is the score and the dashed shape is the bar's target; the tick on each meter marks that same target. Scores with a verified blocker are capped.



Architecture

! Below target

Is it structurally sound?

5 / 10 · target 6

The backend is organized into feature-oriented API, application, and domain packages, with services behind resources.

0 blocker 3 major 1 minor

confidence medium

UI/UX

! Below target

Is it a high-quality product experience?

5 / 10 · target 6

The product has a consistent application shell, Dutch page structure, responsive utility classes, semantic landmarks, and explicit loading/error/success regi...

0 blocker 3 major 3 minor

confidence medium

Code quality

✓ On target

Is the implementation professionally engineered?

6 / 10 · target 6

The codebase is reasonably structured and uses typed domain DTOs and frontend interfaces.

0 blocker 1 major 1 minor

confidence medium

Maintainability

✓ On target

Can it evolve safely?

6 / 10 · target 6

Transition coverage is a clear strength: the coverage map links business transitions to named tests, and the tests assert observable state changes.

0 blocker 0 major 4 minor

Security

× Far below target

Is it safe to deploy?

3 / 10 · target 7

The implementation uses BCrypt for credentials, keeps frontend tokens in memory, validates bearer signatures and expiry, and scopes scan access to the authen...

4 blocker 1 major 3 minor

Scalability

✓ On target

Will it perform as usage grows?

5 / 10 · target 4

The scan portfolio endpoint has a bounded, cursor-based page size and the frontend supports loading additional pages.

0 blocker 0 major 3 minor

confidence medium

confidence high

confidence medium

Data & integration

! Below target

Can we trust boundaries and persisted state?

5 / 10 · target 6

The implementation has good transactional service boundaries, optimistic versions, UUID identifiers, timezone-aware timestamps, and database uniqueness/FK co…

0 blocker 4 major 1 minor

confidence medium

Operations & observability

✓ On target

Can we run it effectively in production?

4 / 10 · target 4

The backend includes SmallRye Health, Micrometer Prometheus, OpenTelemetry, PostgreSQL, and Flyway dependencies, with migrations enabled at startup.

0 blocker 3 major 1 minor

confidence medium

General efficiency

✓ On target

How effectively did the workflow produce all of the above?

9 / 10 · target 5

Computed from run evidence.

deterministic confidence high

Requirements traceability

Every requested acceptance criterion and business rule: is it implemented, and is it proven by a test? "Met" requires a verified implementation *and* a verified test citation. Open a feature for the evidence; the handover lists every open item.

Datavolwassenheidsmodel 0 of 12 met × 7 unmet ◐ 5 partial

Accounttoegang 4 of 7 met ◐ 3 partial

Organisatiecontext en scanrechten 5 of 8 met ◐ 3 partial

Adminomgeving en scaninhoudbeheer 0 of 12 met × 4 unmet ◐ 8 partial

Scanportfolio 4 of 9 met × 2 unmet ◐ 3 partial

Scan aanmaken 4 of 10 met ◐ 6 partial

Kennisgebieden selecteren 0 of 11 met × 2 unmet ◐ 9 partial

Beoordeling vastleggen en hervatten 4 of 11 met × 2 unmet ◐ 5 partial

Beoordelingsinhoud voltooien 5 of 9 met × 4 unmet

Organisatiedoelen en prioriteiten 6 of 11 met ◐ 5 partial

Maturiteitsscores berekenen 3 of 11 met × 4 unmet ◐ 4 partial

Resultaatinzichten en doelcontext 5 of 10 met × 2 unmet ◐ 3 partial

Ontwikkelprioriteiten selecteren 7 of 10 met × 1 unmet ◐ 2 partial

Resultaten exporteren 8 of 13 met × 2 unmet ◐ 3 partial

Afgeronde beoordeling verfijnen 8 of 12 met × 1 unmet ◐ 3 partial

Dimension details

What is good, what is bad, and what needs attention, per dimension. Dimmed findings with a dashed edge have citations that could not be verified; they do not affect scores or the verdict.

Architecture

! 5/10 · Below target — Is it structurally sound?

The backend is organized into feature-oriented API, application, and domain packages, with services behind resources. Contract paths are generally implemented consistently by backend resources and frontend clients. However, frontend authentication headers and problem mapping are repeated in multiple services rather than centralized, and the assessment component directly owns admin-content operations. A scaffold smoke endpoint also remains in the backend production tree.

Needs attention

! Major `arc-01 · ARC-01`

Assessment component owns admin-content operations

Impact: The assessment feature is coupled to domain/question/option administration, making the component a large coordination point and weakening separation between assessment flow and admin capability.

Do this: Move admin workflows into a dedicated admin feature component/facade. Keep the assessment component responsible only for scan context, answers, and completion, with business orchestration in application-level

What is good

Backend uses explicit API, application, and domain layers

app/backend/src/main/java/com/example/account/api/AccountResource.java:3
```
import com.example.account.application.AccountService;
```

app/backend/src/main/java/com/example/account/application/AccountService.java:3
```
import com.example.account.domain.MemberEntity;
```

Contract paths are represented by matching backend resources and frontend clients

app/backend/src/main/java/com/example/result

facades.

Effort M

app/frontend/src/app/maturity-assessment/maturity-assessment.component.ts:5
```
import { AdminContentService, AdminDomain, AdminQuestion, AnswerOption } from '../core/admin-content/admin-content.service';
```

! Major arc-02 · ARC-02

Feature boundaries are blurred in the frontend

Impact Changes to admin content can require edits to the assessment screen, increasing coupling and making ownership, testing, and future authorization changes harder to reason about.

Do this Create a separate admin route/feature boundary and expose admin use cases through an admin facade. Keep shared model types in a neutral contract layer rather than importing admin services into assessment UI.

Effort M

app/frontend/src/app/maturity-assessment/maturity-assessment.component.ts:5
```
import { AdminContentService, AdminDomain, AdminQuestion, AnswerOption } from '../core/admin-content/admin-content.service';
```

app/frontend/src/app/maturity-assessment/maturity-assessment.component.ts:101
```
createDomain(name: string, state: string, versionSourceId: string): void {
```

! Major arc-03 · ARC-03

Frontend auth headers and error mapping are reimplemented per service

Impact Authorization construction and ProblemDetails conversion can diverge across services, while changes to auth transport or error behavior require edits in many files.

Do this Register a single Angular HttpInterceptor for bearer propagation and a centralized ProblemDetails handler. Keep idempotency generation

s/api/ResultsResource.java:20
```
@Path("/v1/scans/{scanId}/results")
```

~~app/frontend/src/app/core/scans/scan-results.service.ts:38~~ (unverified)
```
return this.http.get<ScanResults>(`/v1/scans/${encodeURIComponent(scanId)}/results`, { headers });
```

Backend services centralize organization access checks for scan operations

app/backend/src/main/java/com/example/scan/application/ScanService.java:234
```
private static void requireOrganizationAccess(UUID memberId, UUID organizationId) {
```

Quality-bar criteria

◐ Partial	ARC-01 — Backend API/application/domain separation is clear, but frontend components contain broad orchestration and admin mutations.
◐ Partial	ARC-02 — Feature-oriented backend packages exist, but admin capability is coupled directly into the assessment feature.
× Unmet	ARC-03 — Frontend auth header construction and ProblemDetails mapping are duplicated across services rather than centralized.
✓ Met	ARC-04 — Inspected frontend clients and backend resources use the locked /v1 contract paths, including results, priorities, and export.
× Unmet	ARC-05 — A production /smoke resource remains under com.example.scaffold.

	in a reusable request helper or narrowly scoped endpoint adapter.
Effort	M

app/frontend/src/app/core/organization/organization.service.ts:17
```
const headers = new HttpHeaders({
Authorization: authorization, 'X-
Idempotency-Key': crypto.randomUUID() });
```

app/frontend/src/app/core/scans/scan.service.ts:83
```
private authHeaders(): HttpHeaders {
```

app/frontend/src/app/core/scans/scan-results.service.ts:80
```
private authHeaders(): HttpHeaders {
```

! Minor arc-05 · ARC-05

Smoke scaffolding remains in production backend sources

Impact	The `/smoke` endpoint is unrelated to the product and can be accidentally exposed or mistaken for a supported health contract, creating maintenance and deployment ambiguity.
Do this	Delete the scaffold resource or move it exclusively into test fixtures. Use the existing health endpoint/dependency for operational probes instead of a product-visible resource.
Effort	S

app/backend/src/main/java/com/example/scaffold/SmokeResource.java:8
```
@Path("/smoke")
```

app/backend/src/main/java/com/example/scaffold/SmokeResource.java:14
```
return "ok";
```

UI/UX

! 5/10 · Below target

Is it a high-quality product experience?

The product has a consistent application shell, Dutch page structure, responsive utility classes, semantic landmarks, and explicit loading/error/success regions. Major gaps remain in state completeness, navigation correctness, and field-level validation. Accessibility has useful foundations but misses document language, comprehensive focus coverage, and some labels. Mockup parity cannot be confirmed because the deterministic parity gate was reported as not run.

Needs attention

! Major uiu-01 · UX-01

What is good

Core pages are routed and protected behind the

Requested UI states and visibility rules are incomplete

Impact: The assessment page always renders a general admin-management section after the assessment content, while the requested admin-only visibility rule is not represented in the template. Several empty/error cases are reduced to generic text, and there is no clear UI state for all requested score/model failure variants.

Do this: Model each requested state explicitly per page: empty model/questions, unavailable options, score validation, inaccessible organization, completed/read-only mode, and admin-only visibility. Gate the admin section and actions on the actual role, not only on copy saying “Alleen voor beheerders”.

Effort: M

app/frontend/src/app/maturity-assessment/maturity-assessment.component.html:75
```
<section class="mt-8 rounded-lg border border-primary bg-secondary p-6"><p class="text-sm font-semibold text-primary">Alleen voor beheerders</p>
```

app/frontend/src/app/maturity-assessment/maturity-assessment.component.html:62
```
} @else { <section class="rounded-lg border border-primary bg-secondary p-6"><h2 class="text-2xl font-semibold">Vragenlijst niet beschikbaar</h2>
```

! Major uiu-02 · UX-02

Primary navigation contains an invalid placeholder assessment route

Impact: After authentication, the shell exposes a Beoordeling link to /scans/current/assessment, but assessment routes require a real scan id. Users can therefore land on a non-existent scan context instead of a valid resume flow. Completed scans also expose an assessment action rather than a direct results action in the portfolio.

Do this: Derive the assessment link from the selected or resumable scan, or route to /scans when no scan is selected. In

application guard

app/frontend/src/app/app.routes.ts:9
```
{ path: 'start', component: AccountAccessComponent, title: 'Aanmelden en organisatie starten' }
```

app/frontend/src/app/app.routes.ts:12
```
{ path: 'scans', component: ScanOverviewComponent, canActivate: [authenticatedGuard], title: 'Scanoverzicht' }
```

The shell provides semantic landmarks and primary navigation

app/frontend/src/app/app.html:1
```
<header class="bg-primary text-primary-content shadow-sm">
```

app/frontend/src/app/app.html:5
```
<nav class="ml-auto flex flex-wrap items-center justify-end gap-2" aria-label="Hoofdnavigatie">
```

app/frontend/src/app/app.html:17
```
<main class="min-h-0 flex-1"><router-outlet></router-outlet></main>
```

Important asynchronous states expose status and alert semantics

app/frontend/src/app/scan-results/scan-results.component.html:28
```
@if (resultsService.loading()) {
```

app/frontend/src/app/scan-results/scan-results.component.html:30
```
} @else if (resultsService.problem(); as problem) {
```

app/frontend/src/app/scan-results/scan-results.component.html:31
```
<section class="mb-6 rounded-lg border border-red-700 p-6" role="alert">
```

Assessment and results have clear content hierarchy and primary actions

app/frontend/src/app/maturity-assessment/maturity-assessment.component.html:12
```
<details class="mb-6 rounded-lg border border-primary bg-secondary p-5" open>
```

app/frontend/src/app/scan-results/scan-results.component.html:35

the portfolio, provide separate results navigation for completed scans and assessment navigation only for editable scans.

Effort M

app/frontend/src/app/app.html:10
```
<a routerLink="/scans/current/assessment"
class="rounded-md px-3 py-2 text-sm font-
semibold">Beoordeling</a>
```

app/frontend/src/app/app.routes.ts:10
```
{ path: 'scans/:scanId/assessment',
component: MaturityAssessmentComponent,
canActivate: [authenticatedGuard], title:
'Maturity beoordeling' }
```

! Major uiu-03 · UX-03

Forms lack field-level validation messages and complete client-side constraints

Impact Invalid users receive little guidance about which field is wrong. Required and email validators exist in code, but templates do not render touched/invalid messages; organization and scan fields have no corresponding visible validation feedback, and assessment-period validation is only required.

Do this Add reusable field-error components tied to control.invalid && (dirty || submitted), with Dutch messages for required, email, length, KVK, period format/range, and score constraints. Preserve server Problem Details while mapping field-specific server errors to the same controls; show a clear retry or recovery action for every failed submission.

Effort M

app/frontend/src/app/account-access/account-access.component.html:5
```
<input id="email" type="email"
formControlName="accountIdentifier"
class="w-full rounded-lg border border-
primary bg-body-bg px-4 py-3">
```

app/frontend/src/app/account-access/account-access.component.html:6
```
<label class="block">Organisatienaam<input
formControlName="name" class="mt-2 w-full
rounded-lg border border-primary p-3">
</label>
```

```
<section class="grid gap-6 lg:grid-cols-12"
aria-labelledby="score-heading">
```

Quality-bar criteria

◐ Partial	UX-01 — Loading, error and success regions exist, but several requested states and the admin visibility rule are incomplete or generic.
◐ Partial	UX-02 — All named page routes exist, but the shell uses a literal current scan id and completed-scan navigation is not correctly separated.
◐ Partial	UX-03 — Reactive validators and pending/error states exist, but field-level messages and complete client-side constraints are missing.
◐ Partial	UX-04 — Semantic landmarks, headings, native controls and some focus styling exist; language, labels and focus coverage need work.
◐ Partial	UX-05 — Most product copy is Dutch, but the document language and fallback model strings are English.
◐ Partial	UX-06 — The code has a coherent page hierarchy, but structural mockup parity was not deterministically verified.

Not assessed

- Rendered visual appearance, actual responsive behavior at supported screen sizes, color contrast ratios, and screen-reader output.
- The deterministic mockup structural parity gate because the supplied gate issue reports it as not run.

app/frontend/src/app/scan-overview/scan-overview.component.ts:22

```
readonly createForm =
this.formBuilder.nonNullable.group({ name:
['', Validators.required], assessmentPeriod:
['', Validators.required], domainIds: ['']
});
```

! Minor uiu-04 · UX-04

Accessibility foundations are present but incomplete

Impact	Screen-reader and keyboard users may encounter weaker context and focus behavior: the document declares English while the UI is Dutch, focus styling excludes links/selects/textareas, and several controls rely on implicit labels or generic text rather than explicit accessible names.
Do this	Set lang="nl", apply visible focus styling to :focus-visible for links, buttons, inputs, selects, and textareas, and use explicit for/id labels or aria-labels for every control. Verify keyboard order and announcement behavior with automated and manual accessibility checks.
Effort	S

app/frontend/src/index.html:2

```
<html lang="en">
```

app/frontend/src/app/account-access/account-access.component.scss:2

```
input:focus, button:focus { outline: 2px
solid var(--color-focus, #f59e0b); outline-
offset: 2px; }
```

app/frontend/src/app/scan-overview/scan-overview.component.ts:15

```
<label>Scans zoeken <input class="ml-2
rounded border border-primary p-2"
type="search"
```

! Minor uiu-05 · UX-05

User-facing language is not fully consistent

Impact	The shell and instructions are Dutch, but fallback/example knowledge areas are English and the document language is English. This can make the product feel unfinished and reduces consistency for Dutch users.

Do this	Use Dutch fallback copy or clearly mark model-provided names as intentionally managed content. Align the HTML language, validation messages, placeholders, and all fallback states with the product language.
Effort	S

app/frontend/src/app/account-access/account-access.component.html:7
```
<span>Data Ethics</span>
```

app/frontend/src/app/account-access/account-access.component.html:7
```
<span>Data Governance</span>
```

app/frontend/src/index.html:2
```
<html lang="en">
```

! Minor uiu-06 · UX-06

Mockup parity is not verifiable because the deterministic gate was not run

Impact	The implementation has a plausible hierarchy, but the reported mockup structural parity check for the account slice was not run, so exact section order, spacing, and primary-action parity remain unconfirmed.
Do this	Run the deterministic mockup-parity gate against the account, shell, overview, assessment, and results mockups, then fix any structural differences it reports. Add representative responsive snapshots or equivalent structural assertions for the primary flows.
Effort	M

reports/integration/final/whole-app-check.yaml:7
```
evidence:
```

app/frontend/src/app/maturity-assessment/maturity-assessment.component.html:12
```
<details class="mb-6 rounded-lg border
border-primary bg-secondary p-5" open>
```

Code quality

✓ 6/10 · On target Is the implementation professionally engineered?

Maintainability ✓ 6/10 · On target Can it evolve safely?

Security × 3/10 · Far below target Is it safe to deploy?

The implementation uses BCrypt for credentials, keeps frontend tokens in memory, validates bearer signatures and expiry, and scopes scan access to the authenticated member's organization. However, deployment is blocked by default production secrets/credentials, missing admin role authorization, and an annotation-based authentication mechanism that does not protect newly added endpoints by default. Token claims are incomplete, input and runtime-boundary controls are partial, and security-relevant mutations have no evident audit trail.

Needs attention

× Blocker sec-01 · SEC-01

Authentication is opt-in through a JAX-RS name binding

Impact: The filter is bound only to resources carrying @Authenticated/@BearerAuthenticated. A newly added endpoint can be reachable without authentication unless developers remember both annotations, violating the required deny-by-default behavior.

Do this: Install a global authentication filter or Quarkus security policy that denies every endpoint by default, with an explicit allow-list for the two public authentication operations. Keep endpoint annotations as defense in depth, not as the enforcement boundary.

Effort: M

app/backend/src/main/java/com/example/organization/api/Authenticated.java:9
```
@NameBinding
```

app/backend/src/main/java/com/example/organization/api/BearerAuthenticationFilter.java:9
```
@Authenticated
```

× Blocker sec-02 · SEC-02

Admin endpoints authenticate users but do not authorize a privileged role

Impact: Any authenticated member who can obtain a token can call domain, question, and answer-option management operations. The product explicitly restricts these operations to Beheerder, but no role or admin-scope

What is good

Credentials use an adaptive BCrypt hash

app/backend/src/main/java/com/example/account/application/AccountService.java:55
```
member.credentialHash =
BcryptUtil.bcryptHash(input.credential());
```

Scan access checks organization ownership

app/backend/src/main/java/com/example/scan/application/ScanService.java:238
```
boolean accessible =
OrganizationEntity.count("id = ?1 and
memberId = ?2", organizationId, memberId) >
0;
```

Frontend access tokens are held in memory rather than localStorage

app/frontend/src/app/core/auth/auth.service.ts:28
```
private readonly token = signal<string |
null>(null);
```

Bearer signatures and expiry are checked

app/backend/src/main/java/com/example/organization/application/BearerTokenService.java:53
```
if (payload.path("exp").asLong(0) <=
now.getEpochSecond()) {
```

Quality-bar criteria

× Unmet	SEC-01 — Authentication is attached through a name-bound filter, not enforced globally by default.
× Unmet	SEC-02 — Organization ownership is

check is present.

Do this: Represent roles/privileges in the member model or a trusted role mapping, validate them in the security layer, and enforce a dedicated admin role on every admin read/write. Continue applying organization/resource ownership checks to all user-facing resources.

Effort: L

app/backend/src/main/java/com/example/admin/api/AdminContentResource.java:27
```
@Authenticated
```

app/backend/src/main/java/com/example/admin/api/AdminContentResource.java:28
```
@BearerAuthenticated
```

× Blocker sec-03 · SEC-03

Production configuration has usable default credentials and signing secret

Impact: If deployment does not override these variables, the database uses app/app and tokens use a documented fallback secret. This enables token forgery and weak database access instead of failing safely at startup.

Do this: Remove production fallbacks for database credentials and account.token.secret. Validate required secrets and minimum entropy during production startup and fail fast when absent or using development values.

Effort: S

app/backend/src/main/resources/application.properties:2
```
quarkus.datasource.jdbc.url=${APP_DB_URL:jdbc:postgresql://localhost:5432/app}
```

app/backend/src/main/resources/application.properties:3
```
quarkus.datasource.username=${APP_DB_USERNAME:app}
```

app/backend/src/main/resources/application.properties:6
```
account.token.secret=${ACCOUNT_TOKEN_SECRET:replace-this-development-token-secret-with-at-least-32-characters}
```

checked for scans, but no privileged role enforcement exists for admin endpoints.

× Unmet	SEC-03 — Database credentials and token signing secret have production-usable fallbacks.
◐ Partial	SEC-04 — BCrypt, HMAC signatures, expiry, and session hash checks exist, but issuer/audience and strict JWT claim validation are absent.
◐ Partial	SEC-05 — Bean validation and parameterized queries exist, but most text inputs lack size and format constraints.
◐ Partial	SEC-06 — Tokens are memory-only and no client secret is visible, but header attachment is decentralized.
◐ Partial	SEC-07 — Privileged and security-relevant mutation paths show persistence without an evident audit event.
◐ Partial	SEC-08 — Development CORS is narrow, but production request-size, headers, and origin policy are not established in reviewed configuration.

Not assessed

- TLS termination and certificate configuration outside the application repository
- Production reverse-proxy/WAF request-size and security-header configuration
- Database encryption at rest and operational secret rotation

× Blocker sec-04 · SEC-04

Token validation does not validate issuer or audience

Impact	Tokens have an HS256 signature and exp claim, but no issuer or audience is emitted or checked. Tokens from an unintended issuer/context could be accepted if signed with the shared secret.
Do this	Use a standard JWT implementation or add strict checks for algorithm, issuer, audience, subject, issued-at, and expiry. Configure separate key material per environment and rotate it without accepting defaults.
Effort	M

app/backend/src/main/java/com/example/account/application/AccountService.java:107

```
String header = BASE64_URL.encodeToString("
{\"alg\":\"HS256\",\"typ\":\"JWT\"}".getByte
s(StandardCharsets.UTF_8));
```

app/backend/src/main/java/com/example/organization/application/BearerTokenService.java:53

```
if (payload.path("exp").asLong(0) <=
now.getEpochSecond()) {
```

! Major sec-05 · SEC-05

External string inputs have almost no length or format constraints

Impact	Server validation mostly checks non-blank values, leaving credentials, identifiers, desiredRoute, descriptions, and other text fields without bounded sizes or canonical format validation. This permits oversized payloads and malformed values to reach application and persistence layers.
Do this	Add explicit @Size and format constraints to every textual DTO field, constrain collections and nested values, validate route/identifier formats, and enforce the 1 MB request limit at the HTTP layer. Keep using parameterized Panache queries and add negative validation tests.
Effort	M

app/backend/src/main/java/com/example/account/api/AccountDtos.java:8

```
public record RegistrationInput(@NotBlank
String accountIdentifier, @NotBlank String
credential) {}
```

app/backend/src/main/java/com/example/account/api/AccountDtos.java:12

```
@NotBlank String accountIdentifier,
@NotBlank String credential, String
desiredRoute) {}
```

! Minor sec-06 · SEC-06

Token storage is appropriately in-memory but header propagation is decentralized

Impact	The current services explicitly construct Authorization headers, but every future service must repeat that logic. A missed header can cause inconsistent protection behavior and encourages client-side assumptions about authentication state.
Do this	Retain in-memory token storage, but use a single HttpInterceptorFn to attach the token to API requests and handle 401 responses. Treat route guards only as UX and keep all authorization server-side.
Effort	S

app/frontend/src/app/core/scans/scan.service.ts:86

```
return new HttpHeaders({ Authorization:
authorization });
```

! Minor sec-07 · SEC-07

Privileged content changes have no evident audit logging

Impact	There is no reliable record of which administrator changed model content or which member completed/reopened a scan, limiting incident investigation and accountability.
Do this	Add an append-only audit event service capturing actor, action, resource, organization, timestamp, correlation ID, and outcome for admin mutations and completion/reopen/revision operations. Avoid logging credentials or bearer tokens.
Effort	M

app/backend/src/main/java/com/example/admin/application/AdminContentService.java:52
```
domain.persist();
```

app/backend/src/main/java/com/example/scan/application/ScanService.java:63
```
scan.persistAndFlush();
```

! Minor sec-08 · SEC-08

Runtime boundary controls are incomplete

Impact	Production may accept oversized requests or lack browser protections such as HSTS, frame restrictions, content-type sniffing protection, and an explicit Content-Security-Policy. CORS behavior is only explicitly configured for development.
Do this	Configure a production allow-list from deployment secrets, enforce max request size and timeout at Quarkus/proxy boundaries, and add documented security headers at the edge or application layer. Add startup/configuration tests for these settings.
Effort	M

app/backend/src/main/resources/application.properties:8
```
%dev.quarkus.http.cors.enabled=true
```

app/backend/src/main/resources/application.properties:9
```
%dev.quarkus.http.cors.origins=http://localhost:4200,http://127.0.0.1:4200
```

Scalability ✓ 5/10 · On target Will it perform as usage grows?

Data & integration ! 5/10 · Below target Can we trust boundaries and persisted state?

The implementation has good transactional service boundaries, optimistic versions, UUID identifiers, timezone-aware timestamps, and database uniqueness/FK coverage for many primary relationships. Integrity is incomplete: scan domain selections and answer option references are not database foreign keys, and status/progress values lack database checks. Answer saving does not reject completed or reopened source states, and reopening directly mutates the completed record. The API path/method surface is substantially aligned with OpenAPI, but persistence and lifecycle behavior still contain major correctness gaps.

Needs attention

What is good

! Major dat-01 · DAT-01

Cross-entity integrity is not fully enforced in the database

Impact: scan_selected_domains.domain_id and scan_answers.option_id can reference nonexistent or unrelated records because the migrations do not define foreign keys. Status and progress also accept arbitrary values, allowing invalid persisted state if application validation is bypassed.

Do this: Add foreign keys from scan_selected_domains.domain_id to the model-domain table and scan_answers.option_id to the answer-option table, with appropriate model/scan ownership rules. Add CHECK constraints for status, progress range, priority values, and nonnegative positions. Keep application validation as a second layer, not the only integrity boundary.

Effort: M

app/backend/src/main/resources/db/migration/V6__scan_portfolio.sql:13
```
domain_id UUID NOT NULL,
```

app/backend/src/main/resources/db/migration/V8__scan_answers.sql:5
```
option_id UUID NOT NULL,
```

app/backend/src/main/resources/db/migration/V6__scan_portfolio.sql:6
```
status VARCHAR(32) NOT NULL
```

! Major dat-02 · DAT-02

Answer writes do not guard the source scan state

Impact: saveAnswer is transactional, but it can update an answer and force scan.status to in-progress without rejecting completed or reopened scans. This permits invalid lifecycle transitions and can undermine completion/revision semantics.

Do this: Define an explicit allowed-state matrix for each mutation. Reject answer saves unless the scan is in an answerable state such as concept, in-progress, or an explicitly supported reopened/revision state; require revision creation where policy

Transactional mutation services with optimistic concurrency

app/backend/src/main/java/com/example/scan/application/ScanService.java:25
```
@Transactional
```

app/backend/src/main/java/com/example/scan/application/ScanService.java:76
```
if (scan.version != input.version()) {
```

Database uses opaque UUID identifiers and timezone-aware timestamps

app/backend/src/main/java/com/example/scan/domain/ScanEntity.java:18
```
import java.time.OffsetDateTime;
```

app/backend/src/main/resources/db/migration/V6__scan_portfolio.sql:10
```
updated_at TIMESTAMP WITH TIME ZONE NOT NULL
```

Organization-scoped access is enforced before scan reads and writes

app/backend/src/main/java/com/example/scan/application/ScanService.java:234
```
private static void
requireOrganizationAccess(UUID memberId,
UUID organizationId) {
```

Primary API paths and methods match the locked contract for answers and results

app/backend/src/main/java/com/example/answer/api/AnswerResource.java:20
```
@Path("/v1/scans/{scanId}/answers/{questionId}")
```

app/backend/src/main/java/com/example/answer/api/AnswerResource.java:28
```
@PUT
```

app/backend/src/main/java/com/example/results/api/ResultsResource.java:19
```
@Path("/v1/scans/{scanId}/results")
```

Quality-bar criteria

◐ Partial — DAT-01 — Many NOT NULL, FK, unique, and check constraints exist, but scan domain and answer option references lack database FKs and lifecycle fields lack checks.

demands preservation. Add tests for every forbidden source state.

Effort M

```
app/backend/src/main/java/com/example/answer/application/AnswerService.java:48
answer.optionId = input.optionId();

app/backend/src/main/java/com/example/answer/application/AnswerService.java:60
scan.status = "in-progress";
```

! Major dat-03 · DAT-03

Contract parity is not proven for response behavior and schemas

Impact The resources expose the expected paths and operation IDs, but several methods return plain DTOs while relying on framework defaults for status codes and validation/error mapping. Without verified generated OpenAPI or contract tests, schema-required fields, default error media type, and status behavior can drift from the locked contract.

Do this Generate or inspect the runtime OpenAPI document and add contract tests that assert status, content type, required fields, nullable fields, and Problem response shape for success, validation, conflict, and not-found cases. Explicitly configure exception mapping to application/problem+json.

Effort M

```
app/backend/src/main/java/com/example/scan/api/ScanResource.java:37
@Operation(operationId = "getScan")

app/backend/src/main/java/com/example/scan/api/ScanPortfolioResource.java:51
return
Response.created(URI.create("/v1/scans/" +
scan.id())).entity(scan).build();

locks/contracts/openapi.yaml:28
default:
```

! Major dat-04 · DAT-04

Reopen and priority updates destructively mutate persisted history

Impact Reopening a completed scan changes the same completed row to reopened

◐ Partial	DAT-02 — Writes are transactional and version-guarded, but answer saves do not reject completed/reopened source states.
◐ Partial	DAT-03 — Visible paths, methods, and operation IDs largely match OpenAPI, but runtime response/schema/error parity is not sufficiently demonstrated.
× Unmet	DAT-04 — Completed scans and priority rows are destructively mutated/deleted without an immutable history or revision record.
✓ Met	DAT-05 — UUIDs and OffsetDateTime/TIMESTAMP WITH TIME ZONE are appropriate; progress is floating point but is not monetary data.

Not assessed

- Runtime-generated OpenAPI document and full response schema validation
- Database behavior under concurrent transactions and actual migration startup
- ResultsService persistence and calculation implementation

	and clears completion idempotency state. Development priorities delete all existing rows before inserting replacements. There is no revision/audit table preserving the prior result or priority set, so historical exports and prior completed state can be lost.
Do this	Use immutable assessment revisions or an audit/history table. For reopen, create a new revision or persist an explicit prior-result snapshot before mutation. Version priority sets instead of deleting them, and ensure exports can address the intended revision.
Effort	L

app/backend/src/main/java/com/example/scan/application/ScanService.java:158
```
completed.status = "reopened";
```

app/backend/src/main/java/com/example/priority/application/DevelopmentPriorityService.java:47
```
DevelopmentPriorityEntity.delete("scanId",
scan.id);
```

! Minor dat-05 · DAT-05

Percentage progress uses floating point

Impact	Progress is represented as double/DOUBLE PRECISION. This is not money and is generally acceptable for display, but it can produce fractional precision artifacts and is less deterministic than an integer basis-point or fixed-scale representation.
Do this	Store progress as an integer percentage or fixed-scale numeric if exact reproducibility is required. Continue using UUIDs for identifiers and OffsetDateTime for persisted instants.
Effort	S

app/backend/src/main/java/com/example/scan/domain/ScanEntity.java:29
```
public double progress;
```

app/backend/src/main/resources/db/migration/V6__scan_portfolio.sql:7
```
progress DOUBLE PRECISION NOT NULL
```

Operations & observability ✓ 4/10 · On target Can we run it effectively in production?

Gate truth

Gate results reported by the build agents, checked against the exit codes recorded while the build ran.

84	3	0	138	72
✓ Verified by exit code	× Contradicted	? Unconfirmed claims	Agent judgements (re-reviewed)	Deterministic gates (0 not passed)

Result	Gate	Scope	Command	Claimed	Recorded	Why
× Contradicted	GATE_BUILD	slice-01-accounttoegang · frontend	npx npm run build	unknown	exit 0	Claimed unknown but the last recorded run exited 0.
× Contradicted	GATE_TESTS	slice-01-accounttoegang · frontend	npx npm run test -- --no-watch	unknown	exit 0	Claimed unknown but the last recorded run exited 0.
× Contradicted	GATE_LINT	slice-01-accounttoegang · frontend	npx npm run lint	unknown	exit 0	Claimed unknown but the last recorded run exited 0.

Workflow efficiency

7h 23m	3h 46m	141	25	62%
Wall time	Agent time	Agent attempts	Repair cycles	First-pass rate

41.9M	$56
Tokens	Cost

De workflow had 37 runs, 886 attempts, 25 repair cycles en 20 mislukte agent attempts. De first-pass agent-step rate was 62,3%; de mediane reparatielast was één cyclus per slice. Er waren 84 geverifieerde gates en drie tegengesproken gateclaims, een contradicted rate van 3,45%. De workflow gebruikte 4.501.926 inputtokens en 841.064 outputtokens, met een berekende kost van USD 55,96 en circa 7,4 uur wall-clock tijd. Er is geen ontbrekende efficiencydata gemeld.

Status	Measure	Value
✓ Met	First-pass rate - share of agent steps that succeeded on their first attempt and were never invalidated by a repair.	62%
✓ Met	Repair cycles per slice run (median number of repair invalidations).	1
✓ Met	Escalations raised because a retry budget was exhausted.	0
i Info	Tokens per met acceptance criterion.	66444 0.8
◐ Partial	Share of gate claims contradicted by recorded exit codes (claims that said pass while the command failed).	3%

Handover

De applicatie is niet klaar voor de gevraagde MVP-pilot. Vier security-blockers maken deployment onveilig: authenticatie is opt-in, admin-endpoints missen rolcontrole, productie heeft bruikbare standaardgeheimen en JWT issuer/audience worden niet gevalideerd. Daarnaast zijn modelinhoud en resultaten niet voldoende immutable, worden geselecteerde domeinen niet consequent gefilterd en ontbreken belangrijke resultaat-, admin- en navigatiefuncties. Ook readiness, logging, documentatie en meerdere contract- en validatiecontroles zijn onvoldoende. Eerst moeten de security- en datalifecycleproblemen worden opgelost; daarna kunnen UI, operations en onderhoud worden afgerond en opnieuw gevalideerd.

Ordered work packages to reach the MVP for a limited pilot bar. P0 first.

1 P0 Deny-by-default authenticatie en expliciete admin-autorisatie

effort L WP-01

Maak authenticatie globaal verplicht met alleen expliciet toegestane publieke accountoperaties en voeg een betrouwbare admin-rol of permission guard toe aan alle admin-lees- en schrijffacties.

Closes `sec-01, sec-02, adminomgeving_en_scaninhoudbeheer.s1, adminomgeving_en_scaninhoudbeheer.br1, organisatiecontext_en_scanrechten.s4, organisatiecontext_en_scanrechten.br3, afgeronde_beoordeling_verfijnen.s2, afgeronde_beoordeling_verfijnen.br1, accounttoegang.s3, accounttoegang.br2`

Files
`app/backend/src/main/java/com/example/organization/api/Authenticated.java`
`app/backend/src/main/java/com/example/organization/api/BearerAuthenticationFilter.java`
`app/backend/src/main/java/com/example/admin/api/AdminContentResource.java`
`app/backend/src/main/java/com/example/scan/application/ScanService.java`
`app/backend/src/test/java/com/example/admin/AdminContentBehaviorTest.java`
`app/backend/src/test/java/com/example/scan/ScanResourceTest.java`

Done when

- Een nieuw niet-publiek endpoint is zonder extra annotatie niet bereikbaar zonder geldige sessie.
- Een geldig niet-admin token krijgt 403 op iedere admin read/write-operatie.
- Cross-organization create, update, answer, complete, result- en exportverzoeken worden geweigerd.
- Verlopen of ontbrekende tokens geven 401 op alle organisatiegebonden scanroutes.
- Er bestaan integratietests voor deny-by-default, admin denial en de belangrijkste cross-organization acties.

2 P0 Veilige productieconfiguratie en strikte JWT-validatie

effort M WP-02

Laat productie veilig falen zonder verplichte secrets en valideer JWT-algoritme, issuer, audience, subject, issued-at en expiry met gescheiden keymateriaal per omgeving.

Closes `sec-03, sec-04, ope-03, accounttoegang`

Files
`app/backend/src/main/resources/application.properties`
`app/backend/src/main/java/com/example/account/application/AccountService.java`
`app/backend/src/main/java/com/example/organization/application/BearerTokenService.java`

Done when

- Een productieprofiel start niet wanneer databasecredentials of token secret ontbreken.
- Bekende developmentwaarden zoals app/app en de fallback signing secret worden in productie geweigerd.
- Tokens met verkeerde issuer, audience, algoritme, subject, issued-at of expiry worden geweigerd.
- Er is een configuratietest die veilige productie-initialisatie en negatieve gevallen controleert.

3 P1 Immutable modelsnapshots en correcte scanlifecycle

effort L WP-03

Leg per scan de gebruikte modelinhoud, opties, scores, uitleg en geselecteerde domeinen vast; voorkom destructieve reopen-, priority- en answer-transities en behoud historische resultaten.

Closes `dat-01, dat-02, dat-04, datavolwassenheidsmodel.s4, datavolwassenheidsmodel.br7, adminomgeving_en_scaninhoudbeheer.s3, adminomgeving_en_scaninhoudbeheer.s5, adminomgeving_en_scaninhoudbeheer.br5, adminomgeving_en_scaninhoudbeheer.br6, scanportfolio.s5, beoordeling_vastleggen_en_hervatten.br5, maturiteitsscores_berekenen.s5, maturiteitsscores_berekenen.br6, afgeronde_beoordeling_verfijnen.br5, afgeronde_beoordeling_verfijnen.s2, resultaten_exporteren.s6`

After `WP-01`

Files
`app/backend/src/main/java/com/example/scan/application/ScanService.java`
`app/backend/src/main/java/com/example/scan/domain/ScanEntity.java`
`app/backend/src/main/java/com/example/admin/application/AdminContentService.java`
`app/backend/src/main/java/com/example/priority/application/DevelopmentPriorityService.java`
`app/backend/src/main/resources/db/migration/V6__scan_portfolio.sql`
`app/backend/src/main/resources/db/migration/V8__scan_answers.sql`
`app/backend/src/test/java/com/example/scan/ScanUpdateBehaviorTest.java`
`app/backend/src/test/java/com/example/scan/ResultsBehaviorTest.java`

Done when

- Een bestaande scan blijft na modelwijziging of deactivatie exact dezelfde vragen, opties, uitleg en scores tonen.
- Answer writes op completed of niet-toegestane reopened states worden geweigerd.
- Reopen maakt een nieuwe revision of bewaart aantoonbaar de vorige resultaatsnapshot.
- Priority updates verwijderen geen historische set en exports kunnen de bedoelde revision selecteren.
- Een regressietest voltooit een scan, wijzigt admininhoud en bewijst dat historische resultaten gelijk blijven.

4 P1 Modelvalidatie, relaties en actieve inhoud

effort L WP-04

Borg de zeven vereiste domeinen, unieke vraag- en optie-relaties, actieve-inhoudregels, uitleg en scores in API, persistence en tests.

Closes `dat-01, datavolwassenheidsmodel.s1, datavolwassenheidsmodel.ac2, datavolwassenheidsmodel.ac3, datavolwassenheidsmodel.s5, datavolwassenheidsmodel.br1, datavolwassenheidsmodel.br2, datavolwassenheidsmodel.br3, datavolwassenheidsmodel.br4, datavolwassenheidsmodel.br5, datavolwassenheidsmodel.br6, adminomgeving_en_scaninhoudbeheer.ac4, adminomgeving_en_scaninhoudbeheer.br2, adminomgeving_en_scaninhoudbeheer.br3, adminomgeving_en_scaninhoudbeheer.br4,`

scan_aanmaken.br5, kennisgebieden_selecteren.br2,
beoordeling_vastleggen_en_hervatten.s3, beoordeling_vastleggen_en_hervatten.br2

After WP-03

Files
app/backend/src/main/java/com/example/model/api/ModelDtos.java
app/backend/src/main/java/com/example/model/application/MaturityModelService.java
app/backend/src/main/java/com/example/model/domain/ModelQuestionEntity.java
app/backend/src/main/java/com/example/admin/api/AdminDtos.java
app/backend/src/main/java/com/example/admin/application/AdminContentService.java
app/backend/src/main/java/com/example/scan/application/ScanService.java
app/backend/src/test/java/com/example/model/MaturityModelBehaviorTest.java
app/backend/src/test/java/com/example/admin/AdminContentBehaviorTest.java

Done when

- Modelvalidatie weigert ontbrekende vereiste domeinen, ontbrekende opties en scores buiten 0 tot en met 5.
- Iedere vraag heeft exact één domein en iedere optie exact één vraag via API- en database-invariant.
- Modelresponses bevatten explanation, score en position en leveren opties in beheerde volgorde.
- Nieuwe scans bevatten uitsluitend actieve, geldige inhoud.
- Een test bewijst dat alleen numerieke optiescores de maturity-berekening beïnvloeden.

5 P1 **Geselecteerde domeinen correct opslaan, beantwoorden, voltooien en scoren** effort L WP-05

Gebruik selectedDomainIds consequent voor vragen, answers, voortgang, completion, scores en rapportage en valideer iedere optie tegen de juiste vraag.

Closes dat-02, kennisgebieden_selecteren.s1, kennisgebieden_selecteren.s2, kennisgebieden_selecteren.s3, kennisgebieden_selecteren.ac4, kennisgebieden_selecteren.s5, kennisgebieden_selecteren.s6, kennisgebieden_selecteren.br1, kennisgebieden_selecteren.br3, kennisgebieden_selecteren.br4, kennisgebieden_selecteren.br5, beoordeling_vastleggen_en_hervatten.s1, beoordeling_vastleggen_en_hervatten.s2, beoordeling_vastleggen_en_hervatten.s6, beoordeling_vastleggen_en_hervatten.br1, beoordeling_vastleggen_en_hervatten.br5, beoordelingsinhoud_voltooien.s1, beoordelingsinhoud_voltooien.s2, beoordelingsinhoud_voltooien.br1, beoordelingsinhoud_voltooien.br2, maturiteitsscores_berekenen.s2, maturiteitsscores_berekenen.br1, maturiteitsscores_berekenen.br3, organisatiedoelen_en_prioriteiten.br3

After WP-03, WP-04

Files
app/backend/src/main/java/com/example/scan/application/ScanService.java
app/backend/src/main/java/com/example/answer/application/AnswerService.java
app/backend/src/main/java/com/example/results/application/ResultsService.java
app/backend/src/test/java/com/example/scan/ScanUpdateBehaviorTest.java
app/backend/src/test/java/com/example/scan/SaveAnswerBehaviorTest.java
app/backend/src/test/java/com/example/scan/ResultsBehaviorTest.java
app/frontend/src/app/maturity-assessment/maturity-assessment.component.ts

Done when

- Selecteer alles kiest alle actieve domeinen; doorgaan zonder selectie toont exact de vereiste foutmelding.
- Een vraag of optie uit een niet-geselecteerd of ander domein wordt niet getoond en niet opgeslagen.
- Completion controleert uitsluitend geselecteerde vragen en wordt niet geblokkeerd door niet-geselecteerde domeinen.
- Resultaten en radar-dataset bevatten uitsluitend geselecteerde domeinen.
- PATCH gevolgd door GET/herstart geeft dezelfde selectie, antwoorden en voortgang terug.

6 P1 **Resultaten, aanbevelingen, radar en export contractueel gelijk maken** effort L WP-06

Breid resultaten uit met radar, maturity-levels en aanbevelingen, zorg dat doelen/prioriteiten geen score wijzigen en maak pagina en PDF inhoudelijk gelijk.

Closes `dat-03, maturiteitsscores_berekenen.s3, maturiteitsscores_berekenen.s4, resultaatinzichten_en_doelcontext.s2, resultaatinzichten_en_doelcontext.br1, resultaatinzichten_en_doelcontext.br2, resultaatinzichten_en_doelcontext.br4, resultaten_exporteren.s2, resultaten_exporteren.s3, resultaten_exporteren.s6, resultaten_exporteren.br1, resultaten_exporteren.br2, organisatiedoelen_en_prioriteiten.s1, organisatiedoelen_en_prioriteiten.s5, organisatiedoelen_en_prioriteiten.br2, organisatiedoelen_en_prioriteiten.br6, ontwikkelprioriteiten_selecteren.s4, ontwikkelprioriteiten_selecteren.br1, ontwikkelprioriteiten_selecteren.br4`

After `WP-05`

Files
`app/backend/src/main/java/com/example/results/application/ResultsService.java`
`app/backend/src/main/java/com/example/results/application/ResultsExportService.java`
`app/backend/src/main/java/com/example/priority/application/DevelopmentPriorityService.java`
`app/frontend/src/app/scan-results/scan-results.component.html`
`app/frontend/src/app/scan-results/scan-results.component.spec.ts`
`app/backend/src/test/java/com/example/scan/ResultsBehaviorTest.java`
`app/backend/src/test/java/com/example/results/ResultsExportBehaviorTest.java`

Done when

- De resultatenpagina toont radar, maturity-levels, aanbevelingen en afzonderlijke doel- en ontwikkelprioriteitensecties.
- Het wijzigen van doel, customText of prioriteiten verandert totalScore, domainScores en classificatie niet.
- De PDF bevat exact de titel ‘Organisatiedoelen en prioriteiten’ na de maturity-resultaten.
- Een integratietest vergelijkt alle scores, doelgegevens en duidingsvelden tussen API-resultaat en PDF.
- Prioriteiten voor niet-afgeleide ontwikkelpunten worden geweigerd.

7 P1 Volledig admin- en scanbeheer in een aparte featuregrens

effort L WP-07

Verplaats adminworkflows uit de assessmentcomponent, lever bruikbare adminlijsten/formulieren en borg create/update-permissions en actieve inhoud in de UI.

Closes `arc-01, arc-02, uiu-01, adminomgeving_en_scaninhoudbeheer.s2, adminomgeving_en_scaninhoudbeheer.s6, scan_aanmaken.s1, scan_aanmaken.s3, scan_aanmaken.s4, scan_aanmaken.br1, scan_aanmaken.br2, kennisgebieden_selecteren.s3`

After `WP-01, WP-04`

Files
`app/frontend/src/app/maturity-assessment/maturity-assessment.component.ts`
`app/frontend/src/app/maturity-assessment/maturity-assessment.component.html`
`app/frontend/src/app/core/admin-content/admin-content.service.ts`
`app/frontend/src/app/scan-overview/scan-overview.component.ts`
`app/frontend/src/app/scan-overview/scan-overview.component.spec.ts`
`app/backend/src/main/java/com/example/scan/api/ScanPortfolioResource.java`
`app/backend/src/main/java/com/example/scan/api/ScanDtos.java`

Done when

- Adminfuncties staan achter een afzonderlijke route/feature en worden alleen voor bevoegde gebruikers gerenderd.
- Adminformulieren werken op ondersteunde viewportformaten en hebben tests voor create, edit, activate en deactivate.
- Ongeldige scannaam of beoordelingsperiode voorkomt opslag in frontend én backend.
- Een aangemaakte conceptscan verschijnt met status concept en progress 0 in het portfolio.
- De assessmenttemplate bevat geen directe admin-mutaties meer.

8 P1 Correcte portfolio- en hervatnavigatie

effort M WP-08

Maak scanstatussen en acties correct: completed scans gaan naar resultaten, bewerkbare scans naar assessment en het shell-menu gebruikt geen placeholder-id.

Closes	`uiu-02, scanportfolio.s2, scanportfolio.s4, scanportfolio.br2, scanportfolio.br4, afgeronde_beoordeling_verfijnen.s1, beoordeling_vastleggen_en_hervatten.s6, accounttoegang.br3`
After	`WP-06, WP-07`

Files	`app/frontend/src/app/app.html`
	`app/frontend/src/app/app.routes.ts`
	`app/frontend/src/app/scan-overview/scan-overview.component.ts`
	`app/frontend/src/app/maturity-assessment/maturity-assessment.component.ts`
	`app/frontend/src/app/account-access/account-access.component.ts`

Done when

- Het shell-menu navigeert zonder geselecteerde scan naar /scans en gebruikt nooit /scans/current/assessment.
- Een completed scan toont een link naar /scans/:scanId/results en nooit naar assessment.
- Een concept/in-progress scan hervat op de juiste assessmentroute.
- Na login wordt een niet-standaard desiredRoute daadwerkelijk hersteld.
- API- en componenttests controleren status, progress en updatedAt in elk portfolio-item.

9 P1 Operationele readiness, logging, headers en runbook

effort M WP-09

Maak productie observeerbaar en uitvoerbaar met expliciete datasource-readiness, structured logging, correlation IDs, veilige headers en een volledige root README.

Closes	`ope-01, ope-02, ope-04, sec-08, mai-05`
After	`WP-02`

Files	`app/backend/pom.xml`
	`app/backend/src/main/resources/application.properties`
	`app/backend/src/test/java/com/example/scaffold/SmokeResourceTest.java`
	`app/frontend/package.json`
	`app/backend/pom.xml`
	`README.md`

Done when

- Readiness wordt unhealthy wanneer PostgreSQL onbeschikbaar is en dit is via een integratietest bewezen.
- Requests hebben een bounded correlation ID die in response header en structured logs terugkomt.
- Authorization headers, tokens, wachtwoorden en gevoelige velden worden niet gelogd.
- Productie heeft expliciete request-size, timeout, CORS en browser-security-headerconfiguratie.
- README documenteert prerequisites, database, environment variables, migraties, backend/frontend startup, health/readiness en productieprocedure.

10 P2 Formuliervalidatie, toegankelijkheid en Nederlandstalige UX

effort M WP-10

Geef veldniveau-feedback, complete client/server constraints, correcte documenttaal en consistente focus- en labelondersteuning.

Closes	`uiu-03, uiu-04, uiu-05, accounttoegang.s3, scan_aanmaken.s4, scan_aanmaken.br2, organisatiedoelen_en_prioriteiten.s1, organisatiedoelen_en_prioriteiten.br2`
After	`WP-04, WP-07`

Files	`app/frontend/src/app/account-access/account-access.component.html`
	`app/frontend/src/app/account-access/account-access.component.spec.ts`
	`app/frontend/src/app/account-access/account-access.component.scss`
	`app/frontend/src/app/scan-overview/scan-overview.component.ts`

app/frontend/src/app/maturity-assessment/maturity-assessment.component.html
app/frontend/src/index.html
app/backend/src/main/java/com/example/account/api/AccountDtos.java

Done when

- Elk ongeldig veld toont na dirty/touched of submit een Nederlandstalige, veldspecifieke foutmelding.
- Kopiëren van Problem Details naar controls toont dezelfde veldfouten als clientvalidatie.
- HTML heeft lang="nl", alle controls hebben expliciete labels en :focus-visible is zichtbaar voor links en form controls.
- KVK, email, lengte, periode, scores en tekstvelden hebben begrensde backendvalidatie met negatieve tests.
- Fallback- en modelteksten zijn consistent Nederlands of expliciet als beheerde modelinhoud aangeduid.

11 P2 Contracttests en consistente foutafhandeling

effort M WP-11

Bewijs runtime OpenAPI-pariteit en voorkom dat frontend-subscriptions fouten, loading-statussen of Problem Details verliezen.

Closes	dat-03, cod-01, api-contract, resultaten_exporteren.s2, resultaten_exporteren.br1
After	WP-06
Files	app/backend/src/main/java/com/example/scan/api/ScanResource.java app/backend/src/main/java/com/example/scan/api/ScanPortfolioResource.java locks/contracts/openapi.yaml app/frontend/src/app/scan-results/scan-results.component.ts

Done when

- Contracttests controleren statuscodes, content types, required fields, nullable fields en Problem Details voor success, validation, conflict en not-found.
- Runtime OpenAPI wordt gegenereerd en tegen het gelockte contract vergeleken.
- Resultaat laden, scan laden, exporteren en prioriteit opslaan tonen een actionable foutmelding.
- Alle loading- en saving-flags worden in success én failure via finalize gereset.

12 P2 Frontend infrastructuur en onderhoudbaarheid vereenvoudigen

effort M WP-12

Centraliseer bearer propagation en error mapping, splits ScanService op in gerichte collaborators, pin dependencies en verwijder scaffoldcode.

Closes	arc-03, arc-05, mai-03, mai-04, mai-01, cod-02
After	WP-01, WP-11
Files	app/frontend/src/app/core/organization/organization.service.ts app/frontend/src/app/core/scans/scan.service.ts app/frontend/src/app/core/scans/scan-results.service.ts app/backend/src/main/java/com/example/scan/application/ScanService.java app/backend/src/main/java/com/example/scaffold/SmokeResource.java app/frontend/package.json app/backend/src/test/java/com/example/scan/ScanResourceTest.java app/backend/src/test/java/com/example/scan/ScanUpdateBehaviorTest.java

Done when

- Een Angular HttpInterceptor voegt bearer tokens centraal toe en services bouwen niet langer afzonderlijk Authorization headers.
- Problem Details wordt op één centrale manier genormaliseerd en aan UI-state gekoppeld.
- ScanService is opgesplitst in lifecycle/revision, authorization, idempotency, pagination en mapping collaborators.
- package.json gebruikt exacte dependencyversies met committed lockfile.
- De production /smoke resource is verwijderd of uitsluitend naar testfixtures verplaatst.

- De production /smoke resource is verwijderd of uitsluitend naar testfixtures verplaatst.
- Gedragstests lezen de werkelijke persisted pre-state voordat zij transities assert.

13 P2 Database- en resultaatperformance verbeteren

effort M WP-13

Voorkom volledige collectie-loads en N+1-lookups en voeg ontbrekende relatie-indexen toe.

Closes	sca-01, sca-02, sca-03
After	WP-03
Files	app/backend/src/main/java/com/example/admin/application/AdminContentService.java app/backend/src/main/java/com/example/results/application/ResultsService.java app/backend/src/main/resources/db/migration/V6__scan_portfolio.sql app/backend/src/main/resources/db/migration/V8__scan_answers.sql

Done when

- Admin domain listing pagineert in de database en materialiseert niet de volledige tabel.
- ResultsService gebruikt één joinquery of gebatchte lookups in plaats van question/option findById per answer.
- Migraties bevatten passende indexes voor scan_answers.question_id en scan_selected_domains.domain_id.
- Een representatieve query- of integratietest toont begrensde database-roundtrips voor een assessment.

14 P3 Audittrail en security-operational hardening

effort M WP-14

Maak security-relevante mutaties traceerbaar en vul resterende runtime- en efficiencyverbeteringen aan zonder de MVP-blokkades te omzeilen.

Closes	sec-05, sec-06, sec-07, mai-03, uiu-06, accounttoegang, adminomgeving_en_scaninhoudbeheer.s3, afgeronde_beoordeling_verfijnen.br5
After	WP-09, WP-12
Files	app/backend/src/main/java/com/example/account/api/AccountDtos.java app/backend/src/main/java/com/example/admin/application/AdminContentService.java app/backend/src/main/java/com/example/scan/application/ScanService.java app/frontend/src/app/core/scans/scan.service.ts reports/integration/final/whole-app-check.yaml

Done when

- Alle tekstvelden en collecties hebben expliciete lengte-, formaat- en request-size-limieten met negatieve tests.
- Adminmutaties en completion/reopen/revision-acties schrijven actor, actie, resource, organisatie, tijd, correlation ID en outcome naar een append-only audittrail.
- Auditlogs bevatten geen credentials, bearer tokens of gevoelige requestinhoud.
- Bearer header propagation is uitsluitend centraal geregeld en 401-afhandeling is getest.
- De mockup-parity gate draait voor de genoemde slices en eventuele afwijkingen zijn opgelost of gedocumenteerd.

Method and limits

Requirements come from the product intent. Code was reviewed per dimension by independent, read-only reviewers; every citation they returned was opened and checked (538 of 544 resolved). Verdict, caps and completeness were computed deterministically from verified evidence against the MVP for a limited pilot bar: Usable by a small, known group of real users. Core flows work and are tested, security fundamentals are in place, and operational polish and scale can follow.

Still for a human to check

- De handover is gebaseerd op de door de verifier aangeleverde findings, requirement gaps en efficiencydata; er is geen nieuwe code-inspectie of heruitvoering van tests gedaan.
- De reportdata bevat geen aanvullende notAssessed-items. De mockup-parity-onzekerheid is wel als bestaand finding meegenomen in WP-14.
- UI/UX was judged from code, not from the rendered UI.
- Scalability was inferred from the code. There was no load test.

Generated by the quality-report post-build job · 2026-10-13T18:09:17.178112206Z